

# 医疗AI助手系统 — 软件风险评估说明

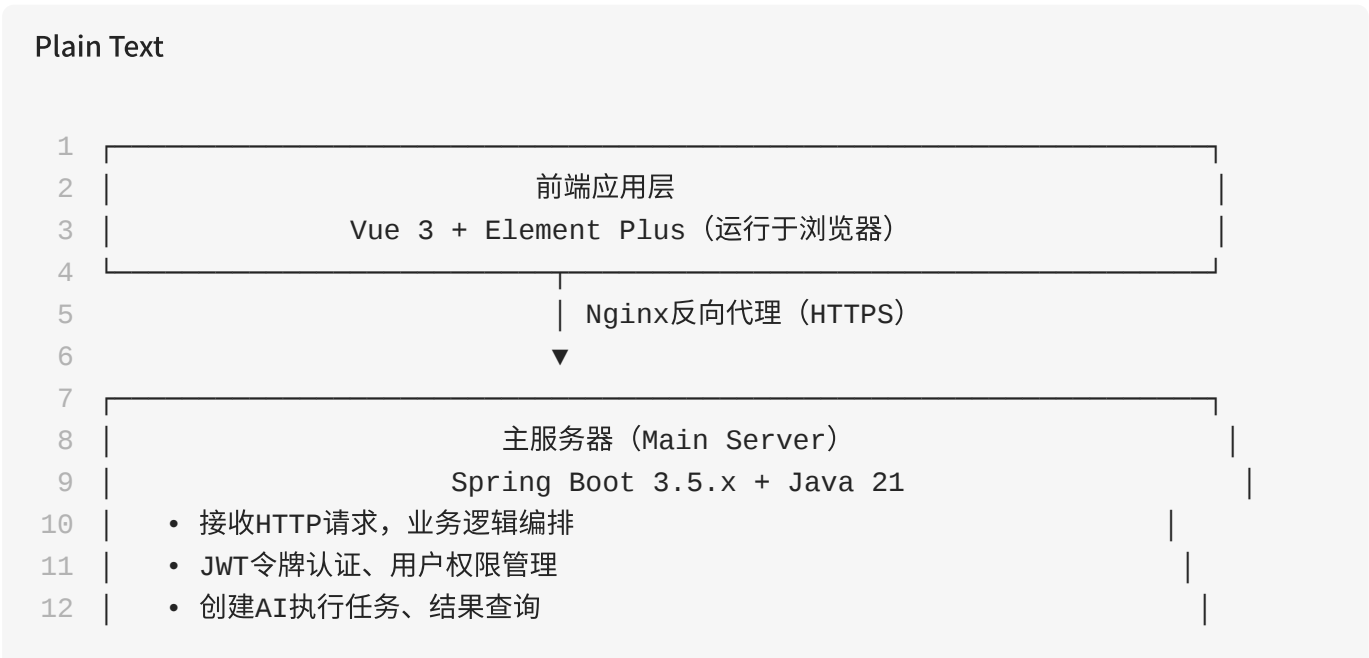
## 一、软件基本信息

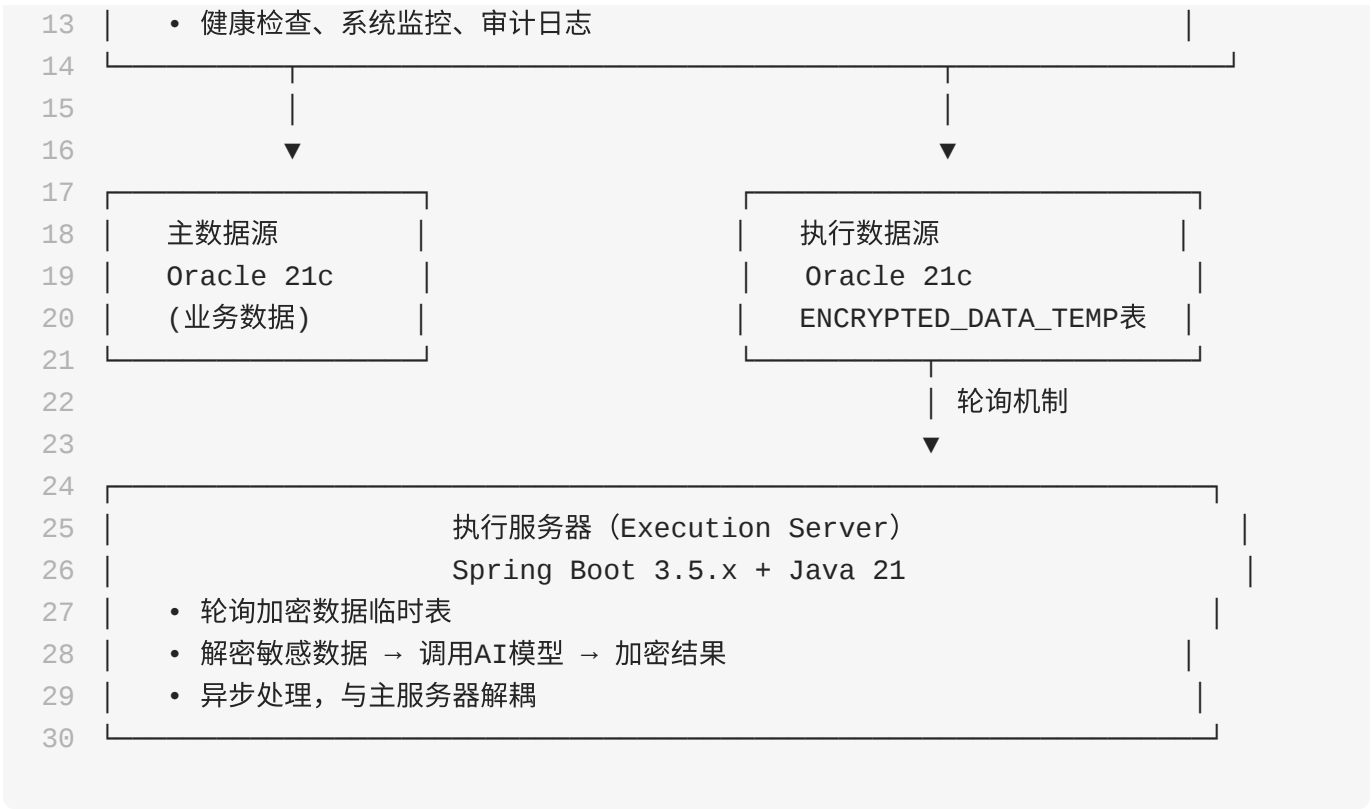
| 项目   | 内容                                             |
|------|------------------------------------------------|
| 软件名称 | 医疗AI助手系统（MedAI Assistant）                      |
| 版本号  | V0.9.080                                       |
| 开发单位 | 自主研发（项目负责人兼具临床医生与软件开发者双重背景）                    |
| 软件类型 | B/S架构的医疗AI辅助诊疗系统                               |
| 运行环境 | 支持 Windows Server 2019+ / Linux（CentOS/Ubuntu） |
| 部署方式 | Docker容器化部署 / 裸机部署（二选一）                        |

## 二、系统架构与技术实现方式

### 2.1 整体架构

系统采用前后端分离 + 双服务器分离架构，由以下组件构成：





|      |         |   |            |
|------|---------|---|------------|
| 语音识别 | 阿里云ASR  | — | 实时语音识别     |
| 构建工具 | Maven   | — | 后端构建       |
| 前端构建 | Webpack | — | 前端打包       |
| 容器化  | Docker  | — | 容器部署       |
| 反向代理 | Nginx   | — | 负载均衡与SSL终止 |

2.3 网络架构与端口说明

| 组件        | 端口     | 协议         | 说明        |
|-----------|--------|------------|-----------|
| 主服务器      | 8081   | HTTP/HTTPS | 业务API服务   |
| 执行服务器     | 8082   | HTTP       | AI异步任务处理  |
| 前端Nginx   | 80/443 | HTTP/HTTPS | 静态资源与反向代理 |
| Oracle数据库 | 1521   | Oracle Net | 数据库连接     |

三、数据走向（安全视角）

3.1 数据来源

- 系统仅从**医院内网Oracle数据库**读取在院患者的医疗数据（患者基本信息、诊断、病历、检验检查、医嘱），不做写回HIS/EMR操作
- 所有数据通过**内网专线**传输，不经过公网

3.2 数据加密流转



关键安全措施：

- 敏感数据全程以AES-256-CBC密文形式存储在临时表中，明文永不落地
- 解密仅在进程内存中完成，处理完毕后立即清理
- 主服务器与执行服务器通过临时表异步解耦，不直接网络互通
- 每次加密使用随机IV（初始化向量），确保相同数据每次密文不同

3.3 网络安全边界

- 前端 → Nginx：HTTPS加密传输
- Nginx → 主服务器：内网HTTP，Nginx终止SSL
- 主服务器 → Oracle数据库：内网Oracle Net协议
- 执行服务器 → AI模型API：仅出站HTTPS，可配置IP白名单
- 所有服务部署于医院内网，对外不暴露端口（AI调用除外）

四、数据安全和隐私保护

4.1 安全架构分层

| 安全层 | 措施                                           |
|-----|----------------------------------------------|
| 网络层 | HTTPS/TLS加密传输、防火墙配置、内网部署隔离                   |
| 应用层 | Spring Security、JWT令牌认证（HMAC-SHA256）、会话无状态管理 |
| 数据层 | AES-256-CBC加密（敏感数据）、Argon2密码哈希、PBKDF2密钥派生    |
| 接口层 | Jakarta Bean Validation参数校验、限流控制、错误码规范化      |
| 审计层 | 完整操作日志审计、数据变更追踪                              |

4.2 数据加密机制

- **传输加密：**全程采用AES-256-CBC算法，随机IV（初始化向量），PKCS5Padding填充
- **密钥管理：**密钥与盐值存储于数据库配置表，不同环境隔离，支持密钥轮换
- **加密流程：**主服务器加密 → 写入临时表（密文） → 执行服务器读取解密 → 调用AI → 结果加密写回 → 主服务器解密读取
- **明文不落地：**敏感数据在整个流转过程中以密文形式存储于数据库，仅在服务进程内存中解密，处理完成后立即清理

4.3 认证与授权

- 采用JWT（JSON Web Token）无状态认证方案
- 令牌默认24小时过期，HMAC-SHA256签名
- 基于角色的访问控制（RBAC）
- 登录密码采用Argon2安全哈希算法存储
- 支持用户激活/停用状态管理

4.4 数据隔离

- 系统仅读取患者医疗数据（在院患者），不做写回HIS/EMR操作
- 所有AI分析结果以辅助参考形式呈现，最终临床决策权在医生
- 不与外部互联网直接互通，通过内网专线/VPN与医院信息系统对接

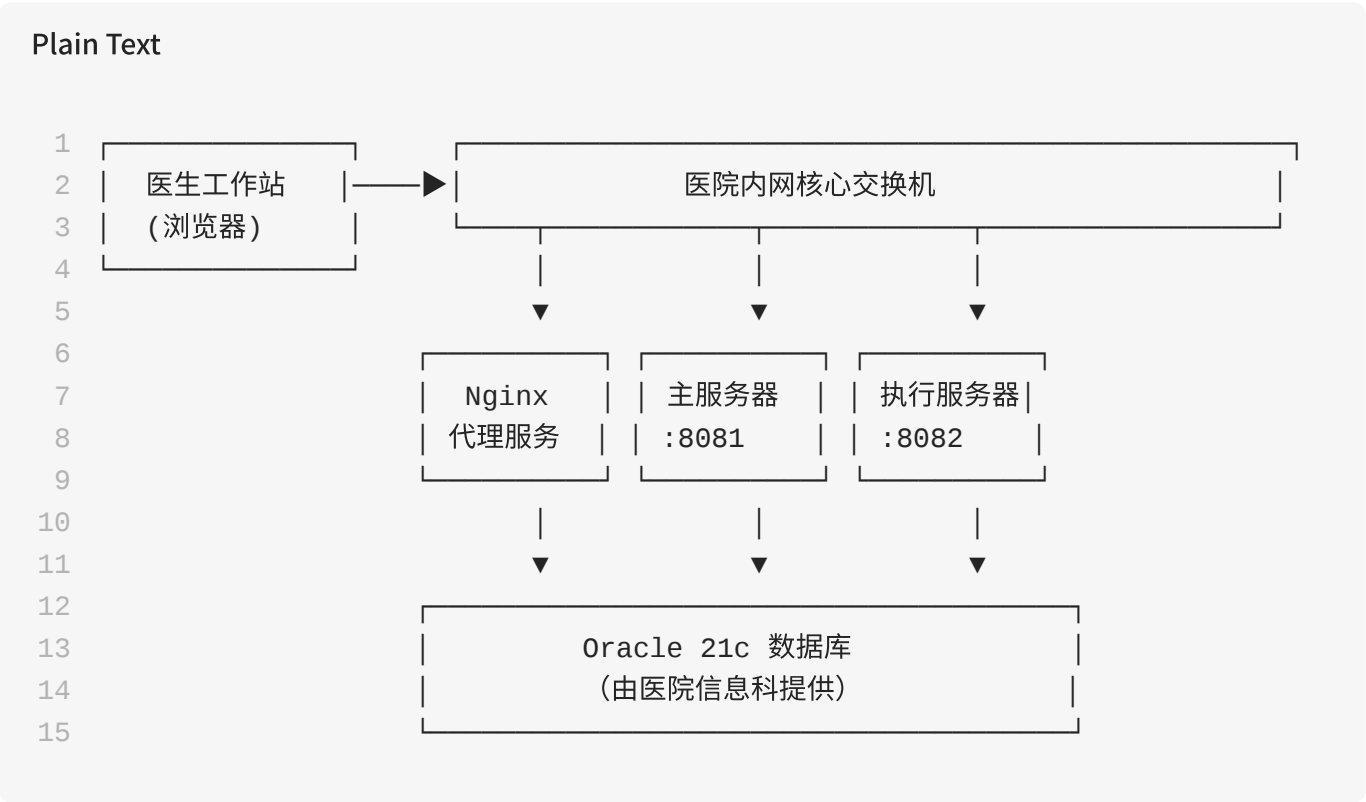
五、系统可靠性与容错机制

| 机制     | 说明                                        |
|--------|-------------------------------------------|
| 双服务器解耦 | 主服务器与执行服务器分离，AI调用故障不影响主业务流程               |
| 异步轮询   | 主-执间通过数据库临时表异步通信，避免同步阻塞                   |
| 连接池管理  | HikariCP连接池（最大5连接），HttpClient连接池（最大200连接） |
| 超时控制   | HTTP连接超时3s、Socket超时5min、请求超时10s           |

|      |                              |
|------|------------------------------|
| 自动恢复 | 内置AutoRecoveryEngine自动故障恢复机制 |
| 健康检查 | 数据库连接、网络状态、系统资源实时监控          |
| 重试机制 | AI调用支持指数退避重试、熔断保护            |
| 限流保护 | 请求频率限制和队列管理                  |
| 日志追溯 | 请求ID贯穿全链路，支持问题定位             |

## 六、部署方案与网络拓扑

### 6.1 推荐部署拓扑（院内内网）



### 6.2 硬件配置建议

| 服务器角色 | CPU | 内存    | 硬盘        | 数量 |
|-------|-----|-------|-----------|----|
| 主服务器  | 4核+ | 8GB+  | 100GB SSD | 1台 |
| 执行服务器 | 4核+ | 16GB+ | 100GB SSD | 1台 |

|           |     |       |        |           |
|-----------|-----|-------|--------|-----------|
| Oracle数据库 | 8核+ | 16GB+ | 500GB+ | 由医院现有环境提供 |
|-----------|-----|-------|--------|-----------|

6.3 网络要求

- 主服务器、执行服务器、数据库服务器之间需内网互通
- 执行服务器需可访问互联网（调用AI大模型API，医院防火墙可配置白名单）
- 医生工作站通过内网浏览器访问Nginx代理（HTTP/HTTPS）

七、风险分析与应对措施

7.1 数据安全风险

| 风险项        | 风险等级 | 应对措施                         |
|------------|------|------------------------------|
| 患者隐私数据泄露   | 高    | AES-256全链路加密，明文不落地，最小权限原则    |
| 数据库未授权访问   | 高    | 仅限内网访问，绑定IP白名单，最小权限数据库账户     |
| JWT令牌劫持    | 中    | HMAC-SHA256签名，24小时过期，HTTPS传输 |
| AI模型输出敏感信息 | 中    | AI返回结果经过脱敏后存储，不包含明文患者标识      |

7.2 系统可靠性与业务连续性风险

| 风险项         | 风险等级 | 应对措施                      |
|-------------|------|---------------------------|
| 主服务器单点故障    | 中    | 支持水平扩展部署，Docker容器化快速恢复    |
| AI模型外部服务不可用 | 中    | 异步解耦，AI调用失败不影响主业务，支持重试与降级 |

|         |   |                          |
|---------|---|--------------------------|
| 数据库连接异常 | 中 | HikariCP健康检查、自动重连、自动恢复引擎 |
| 网络中断    | 中 | 重试机制、状态机确保数据一致性、幂等性设计    |

7.3 临床使用风险

| 风险项       | 风险等级 | 应对措施                              |
|-----------|------|-----------------------------------|
| AI建议误导诊疗  | 中    | AI结果仅作参考，不替代医生决策，前端明确标注"AI建议仅供参考" |
| 数据同步延迟    | 低    | 定时任务轮询同步，状态可追溯，医生可手动刷新            |
| 误操作导致数据问题 | 低    | 操作审计日志完整记录，支持数据回溯                 |

八、合规与资质说明

| 事项     | 说明                              |
|--------|---------------------------------|
| 软件性质   | 辅助诊疗工具，非医疗器械，不替代医生独立决策          |
| 数据处理范围 | 仅读取医院内网患者医疗数据，不做写入HIS/EMR操作     |
| 数据存储位置 | 所有数据存储于医院自有Oracle数据库内，不外传       |
| AI服务   | 调用第三方AI大模型API时，传输加密后的脱敏数据       |
| 审计追踪   | 所有操作记录完整审计日志，可追溯至具体用户与时间        |
| 合规标准   | 设计遵循医疗行业数据安全标准，支持HIPAA/GDPR合规要求 |

---

编制单位：医疗AI助手系统开发团队

文档版本：V1.0

编制日期：2026年5月11日